

Questionário de Maturidade em Gestão de Riscos de TI

Questionário aplicado nos órgãos municipais: 134 itens. A Seção 0 (núcleo obrigatório) vale para todos os órgãos; cada uma das outras 22 só é respondida quando a pergunta de triagem dela recebe "sim".

Escala de resposta (a mesma em todos os itens):

- Adota integralmente, com monitoramento e maturidade definida — o nível anterior, mais indicador acompanhado, evidência e revisão periódica.
- Adota integralmente — documentado, com responsável designado, cobrindo todo o escopo pertinente e executado de forma consistente.
- Adota parcialmente — há norma ou procedimento documentado, mas a cobertura é incompleta ou a execução é irregular.
- Adota informalmente — a prática ocorre na rotina, sem norma escrita, sem responsável formal e dependente de pessoas específicas.
- Não adota — o controle não existe, ou existe apenas como intenção ou projeto não iniciado.

Seção 0. Núcleo obrigatório

Esta seção é obrigatória e vale para todos os órgãos.

1. Existe plano diretor de TI vigente, aprovado e com revisão periódica documentada?

Evidência esperada: PDTIC (Plano Diretor de Tecnologia da Informação e Comunicação) aprovado; atas do comitê; relatórios de acompanhamento; vínculo entre contratações e plano · Indicador sugerido: % de contratações de TI vinculadas ao plano; % de metas do plano executadas; meses desde a última revisão

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

2. Existe política de segurança da informação aprovada, publicada, com revisão periódica e ciência formal dos usuários?

Evidência esperada: PSI (Política de Segurança da Informação) publicada; atos de aprovação; termos assinados; registros de treinamento e comunicação · Indicador sugerido: % de servidores com termo de ciência assinado; meses desde a última revisão; nº de normas complementares pendentes

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

3. Existe metodologia formal de gestão de riscos de TI, com matriz atualizada, responsáveis e prazos de tratamento?

Evidência esperada: Metodologia aprovada; matriz de riscos; planos de tratamento com responsável e prazo; atas de revisão · Indicador sugerido: % de processos críticos com risco avaliado; nº de riscos altos/extremos sem plano; atraso médio dos planos de ação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

4. Existe matriz de requisitos legais aplicáveis à TI, com verificação periódica de conformidade?

Evidência esperada: Matriz de requisitos; pareceres; checklists de conformidade; relatórios de auditoria · Indicador sugerido: Nº de não conformidades abertas; % de sistemas com checklist legal aprovado; prazo médio de adequação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

5. Existe inventário atualizado de ativos de TI, com responsável, localização, criticidade e ciclo de vida?

Evidência esperada: Inventário; relatórios de descoberta; termos de responsabilidade; atas de conciliação · Indicador sugerido: % de ativos com responsável definido; divergência entre descoberta e inventário; nº de ativos órfãos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

6. Existe cofre corporativo de senhas e política aplicada tecnicamente para complexidade, rotação e não reutilização?

Evidência esperada: Cofre implantado com registros de uso; política de senhas; relatórios de auditoria · Indicador sugerido: % de senhas críticas no cofre; nº de segredos encontrados em repositórios; nº de credenciais vazadas identificadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

7. Existe varredura periódica de vulnerabilidades com priorização, prazos de correção e acompanhamento das pendências?

Evidência esperada: Relatórios de varredura; plano de correção com prazos; registros de aplicação de patches · Indicador sugerido: Nº de vulnerabilidades críticas abertas; tempo médio de correção por severidade; % do parque varrido

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

8. Existe política de backup com regra 3-2-1 (três cópias dos dados, em dois tipos de mídia diferentes, sendo uma delas guardada fora do órgão), cópia isolada e testes de restauração documentados?

Evidência esperada: Política; relatórios de execução; registros de teste de restauração com tempo medido; inventário de escopo ·
Indicador sugerido: % de sistemas críticos com backup testado; nº de falhas de rotina; tempo real de restauração x RTO (tempo máximo tolerado até o serviço voltar a funcionar)

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

9. Existe análise de impacto nos negócios, com RTO (tempo máximo tolerado até o serviço voltar a funcionar) e RPO (perda máxima de dados tolerada, medida pelo tempo desde a última cópia) definidos, plano de continuidade documentado e testado?

Evidência esperada: BIA (análise de impacto nos negócios); planos aprovados; registros e relatórios de testes; atas de simulação ·
Indicador sugerido: % de serviços críticos com RTO/RPO definidos; data do último teste; tempo de recuperação medido x RTO

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

10. Existem backups imutáveis e isolados, EDR (ferramenta que detecta e bloqueia ataques em computadores e servidores) com monitoramento, MFA (autenticação em mais de um fator, como senha e código no celular) no acesso remoto e plano de resposta específico para ransomware?

Evidência esperada: Plano de resposta a ransomware; evidências de backup imutável testado; relatórios de EDR; simulações ·
Indicador sugerido: % de backups imutáveis testados; cobertura de EDR; tempo de detecção e de contenção em exercícios

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

11. Existe plano de resposta a incidentes com equipe designada, classificação, fluxo de comunicação e prazos definidos?

Evidência esperada: Plano aprovado; registros de incidentes; comunicações realizadas; relatórios pós-incidente ·
Indicador sugerido: Tempo médio de detecção e de contenção; % de incidentes com registro completo; nº de exercícios realizados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

12. Existe programa contínuo de conscientização, com trilhas específicas para a equipe técnica e registro de participação?

Evidência esperada: Plano de capacitação; listas de presença e certificados; resultados de simulações ·
Indicador sugerido: % de servidores treinados no ano; taxa de cliques em simulações de phishing; nº de incidentes por conduta

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

13. O dimensionamento da equipe de TI é compatível com os serviços mantidos, incluindo segurança e continuidade?

Evidência esperada: Estudo de dimensionamento; indicadores de rotatividade; plano de capacitação · Indicador sugerido: Rotatividade anual da equipe; nº de demandas em fila; nº de atividades críticas sem responsável

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

14. Existe política de uso aceitável divulgada, com termo de ciência e controles técnicos compatíveis?

Evidência esperada: Política publicada; termos assinados; configuração dos filtros; registros de apuração · Indicador sugerido: Nº de bloqueios por categoria; nº de apurações; % de termos assinados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 1. Unidades autônomas

Pergunta de triagem: O órgão possui várias unidades ou áreas com autonomia para contratar tecnologia? ☐

Sim ☐ Não

Se "não", passe para a próxima seção.

15. Existem designações formais de gestor de segurança, donos de sistemas e responsáveis por ativos críticos?

Evidência esperada: Portarias; matriz RACI (quem executa, quem responde, quem é consultado e quem é informado); inventário de sistemas com donos; atas do comitê · Indicador sugerido: % de sistemas críticos com dono formal; nº de designações vagas; tempo médio para redesignação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

16. Existe processo de homologação de soluções e mecanismo para identificar serviços não autorizados em uso?

Evidência esperada: Catálogo homologado; relatórios de descoberta; registros de regularização · Indicador sugerido: Nº de serviços não homologados identificados; % regularizados; tempo médio de homologação de novas demandas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

17. A conexão central de internet do órgão (a que atende a sede e o datacenter) tem um segundo link, de outra operadora, que assume automaticamente quando o principal cai — e essa troca já foi testada?

Orientação: link é a conexão de internet contratada de uma operadora. Dois links da mesma operadora, ou que chegam pelo mesmo cabo ou poste, não contam como redundância; um link móvel (4G/5G) de outra operadora conta. · Evidência esperada: Contratos com SLA (nível de serviço contratado: prazos e disponibilidade garantidos); topologia de conectividade; registros de testes de failover e de indisponibilidade · Indicador sugerido: Disponibilidade mensal por unidade; tempo médio de restabelecimento; % de unidades críticas com redundância

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 2. Operação continuada

Pergunta de triagem: O órgão mantém serviços de TI em operação continuada? ☐ Sim ☐ Não
Se "não", passe para a próxima seção.

18. Existe previsão orçamentária plurianual para sustentação, renovação e segurança de TI?

Evidência esperada: Peça orçamentária; mapa de contratos e vencimentos; atas de priorização · Indicador sugerido: Nº de contratos críticos vencendo em 120 dias sem processo iniciado; % de execução orçamentária de TI

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

19. Existem indicadores de disponibilidade, desempenho e segurança acompanhados periodicamente pela gestão?

Evidência esperada: Catálogo de serviços; painéis; atas de revisão; relatórios de disponibilidade · Indicador sugerido: Disponibilidade mensal por serviço crítico; tempo médio de atendimento; % de serviços com meta definida

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

20. A arquitetura, as configurações e os procedimentos operacionais estão documentados, atualizados e acessíveis à equipe?

Evidência esperada: Repositório de documentação; diagramas atualizados; POP (procedimento operacional padrão); termos de aceite com documentação entregue · Indicador sugerido: % de sistemas críticos documentados; idade média da documentação; nº de aceites sem documentação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 3. Processos críticos

Pergunta de triagem: O órgão opera processos digitais com impacto financeiro, patrimonial ou em direitos? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

21. Existe matriz de segregação de funções aplicada aos perfis dos sistemas críticos?

Evidência esperada: Matriz de segregação; relatórios de conflito tratados; registros de dupla aprovação · Indicador sugerido: N° de usuários com conflito de perfil; % de operações críticas com dupla aprovação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

22. Existem controles de integridade, validação de consistência e restrição ao acesso direto às bases de produção?

Evidência esperada: Procedimento de alteração em massa; registros de aprovação; relatórios de conciliação · Indicador sugerido: N° de ajustes diretos em banco; n° de inconsistências detectadas; volume de registros corrigidos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

23. Existe monitoramento de consultas atípicas e termo de responsabilidade assinado por todos os usuários?

Evidência esperada: Termos assinados; relatórios de auditoria de consultas; registros de apuração · Indicador sugerido: N° de consultas atípicas identificadas; n° de apurações abertas; % de usuários com termo assinado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 4. Ambiente próprio

Pergunta de triagem: O órgão mantém servidores, rede local ou equipamentos próprios em suas instalações?

☐ Sim ☐ Não

Se "não", passe para a próxima seção.

24. Existe um padrão escrito de configuração segura (hardening) para servidores, computadores e equipamentos de rede — por exemplo, trocar senhas de fábrica e desativar serviços sem uso — e é possível conferir quais equipamentos estão fora dele?

Orientação: o padrão pode ser um checklist de instalação, uma imagem padrão de sistema, políticas de grupo (GPO) ou scripts de configuração. Conferir significa ter relatório ou ferramenta que aponte os equipamentos fora do padrão, e não apenas confiar que foram configurados corretamente. · Evidência esperada: Documentos de baseline; relatórios de conformidade; imagens padronizadas; scripts de provisionamento · Indicador sugerido: % de ativos conformes ao baseline; n° de desvios críticos abertos; tempo médio de remediação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

25. Toda alteração de configuração em produção é registrada, aprovada e reversível?

Evidência esperada: Registros de mudança (RDM (requisição de mudança)); histórico de versões de configuração; logs administrativos · Indicador sugerido: % de mudanças com registro formal; nº de incidentes causados por mudança; taxa de rollback

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

26. A rede é segmentada por perfil de uso, com regras de filtragem entre segmentos e rede separada para visitantes e dispositivos?

Evidência esperada: Diagrama de rede segmentada; matriz de comunicação permitida; configuração de firewall; testes de segmentação · Indicador sugerido: Nº de zonas definidas x implementadas; nº de regras 'any-any'; resultado dos testes de isolamento

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

27. A sala técnica possui controle de acesso, climatização adequada, detecção de incêndio e proteção elétrica com manutenção comprovada?

Evidência esperada: Registros de acesso; laudos de manutenção; relatórios de monitoramento ambiental; testes de nobreak · Indicador sugerido: Nº de alarmes ambientais; tempo desde a última manutenção preventiva; autonomia real do nobreak

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

28. Existe nobreak com autonomia conhecida, gerador quando aplicável, testes periódicos e desligamento automatizado seguro?

Evidência esperada: Laudos de manutenção; registros de testes; relatórios de autonomia; procedimento de desligamento · Indicador sugerido: Autonomia medida x requerida; nº de desligamentos abruptos; idade das baterias

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

29. A gerência do ambiente virtualizado é isolada, com MFA (autenticação em mais de um fator, como senha e código no celular), atualizada e com backups fora do mesmo cluster?

Evidência esperada: Diagrama do ambiente; configuração de rede de gerência; registros de atualização; testes de restauração · Indicador sugerido: Versão x versão suportada do hipervisor; % de backups fora do cluster; nº de administradores com acesso

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

30. Todos os endpoints possuem proteção ativa, atualizada e gerenciada por console central, sem privilégio de desabilitação pelo usuário?

Evidência esperada: Relatórios de cobertura da console; políticas aplicadas; registros de incidentes tratados · Indicador sugerido: % de endpoints com agente ativo e atualizado; nº de detecções por mês; tempo médio de contenção

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

31. Existem cópias de dados e capacidade de processamento em local geograficamente distinto?

Evidência esperada: Contratos de site alternativo ou nuvem; registros de backup externo; testes de recuperação; laudos prediais · Indicador sugerido: Distância entre site principal e cópia externa; tempo de recuperação em teste; nº de não conformidades prediais

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 5. Parque tecnológico

Pergunta de triagem: O órgão mantém equipamentos e softwares licenciados sob sua responsabilidade? ☐

Sim ☐ Não

Se "não", passe para a próxima seção.

32. Existe controle de datas de fim de suporte dos ativos, com plano de atualização ou migração?

Evidência esperada: Mapa de EOL (fim de vida: equipamento ou software sem suporte do fabricante); plano de migração; registros de isolamento e controles compensatórios · Indicador sugerido: % de ativos fora de suporte; nº de ativos críticos com EOL em 12 meses; idade média do parque

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

33. Existe procedimento formal de sanitização com registro antes de qualquer saída de equipamento ou mídia?

Evidência esperada: Termos de sanitização e destruição; laudos; registros de baixa com verificação · Indicador sugerido: % de baixas com termo de sanitização; nº de equipamentos liberados sem verificação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

34. Existe inventário de software com conciliação periódica entre instalações e licenças contratadas?

Evidência esperada: Inventário de software; contratos e notas de licença; relatórios de conciliação · Indicador sugerido: N° de instalações sem licença; % de estações com software não autorizado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 6. Internet e capacidade

Pergunta de triagem: O órgão mantém serviços acessíveis pela internet ou com demanda variável? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

35. Existe inventário do que está publicado na internet, com revisão periódica e justificativa para cada exposição?

Evidência esperada: Inventário de superfície externa; relatórios de varredura; registros de aprovação de publicação · Indicador sugerido: N° de portas/serviços expostos; n° de exposições não justificadas; tempo médio para fechar exposição indevida

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

36. Existe monitoramento de capacidade com limiares, projeção de crescimento e plano de expansão?

Evidência esperada: Relatórios de capacidade; registros de alerta; testes de carga; plano de expansão · Indicador sugerido: % de utilização média e de pico; n° de incidentes por saturação; dias até esgotamento projetado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

37. Os logs de segurança são centralizados, retidos, correlacionados e monitorados com regras de alerta?

Evidência esperada: Arquitetura de coleta; casos de uso implantados; relatórios de alertas tratados · Indicador sugerido: % de fontes críticas integradas; tempo médio de detecção; n° de alertas tratados por período

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

38. Todos os ativos sincronizam horário com fonte confiável e os logs são armazenados de forma protegida contra alteração?

Evidência esperada: Configuração de NTP (protocolo que sincroniza o horário dos equipamentos); arquitetura de logs; permissões do repositório; registros de verificação · Indicador sugerido: Desvio máximo de horário entre ativos; % de fontes enviando logs ao repositório central

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 7. Wi-Fi e impressão

Pergunta de triagem: O órgão oferece rede sem fio ou usa impressoras compartilhadas em rede? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

39. Existe bloqueio automático de tela e expiração de sessão configurados nas estações e nas aplicações?

Evidência esperada: Políticas aplicadas no diretório; configuração das aplicações; registros de inspeção · Indicador sugerido: % de estações com bloqueio configurado; duração média de sessão nas aplicações críticas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

40. A rede sem fio corporativa usa autenticação individual e está segregada da rede de visitantes e de dispositivos?

Evidência esperada: Configuração dos controladores; diagrama de SSIDs (nomes das redes sem fio); relatórios de varredura · Indicador sugerido: N° de pontos de acesso não inventariados; % de redes com autenticação individual; n° de dispositivos desconhecidos conectados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

41. As multifuncionais possuem senha alterada, firmware atualizado, impressão com liberação e sanitização prevista em contrato?

Evidência esperada: Configuração dos equipamentos; contrato com cláusula de sanitização; registros de liberação de impressão · Indicador sugerido: % de equipamentos com senha padrão alterada; n° de documentos não retirados; versões de firmware desatualizadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 8. Acesso privilegiado

Pergunta de triagem: O órgão utiliza acessos administrativos, remotos ou autenticação centralizada? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

42. Os privilégios administrativos são nominais, mínimos, temporários e revisados periodicamente?

Evidência esperada: Relatórios de revisão de acesso; registros do cofre; matriz de perfis; logs de elevação · Indicador sugerido: N° de contas com privilégio administrativo; % com MFA (autenticação em mais de um fator, como senha e código no celular); n° de acessos privilegiados sem justificativa

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

43. O MFA (autenticação em mais de um fator, como senha e código no celular) está habilitado para acesso remoto, e-mail, nuvem e todas as contas privilegiadas?

Evidência esperada: Configuração do provedor de identidade; relatórios de cobertura de MFA; política de senhas publicada · Indicador sugerido: % de contas críticas com MFA; n° de acessos suspeitos bloqueados; n° de credenciais institucionais em vazamentos públicos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

44. Todo acesso remoto ocorre por VPN (conexão remota criptografada com a rede do órgão) com MFA (autenticação em mais de um fator, como senha e código no celular), com escopo restrito, registro de sessão e revogação ao término?

Evidência esperada: Configuração de VPN e firewall; relatórios de varredura externa; logs de sessão; termos de acesso de fornecedor · Indicador sugerido: N° de serviços administrativos expostos à internet; % de acessos remotos com MFA; n° de sessões de fornecedor sem registro

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

45. O provedor de identidade possui redundância, monitoramento de certificados e procedimento de acesso de emergência?

Evidência esperada: Arquitetura documentada; registros de teste de failover; controle de certificados; procedimento break-glass · Indicador sugerido: Disponibilidade do provedor de identidade; dias até a expiração dos certificados; data do último teste de failover

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 9. Contas de usuários

Pergunta de triagem: O órgão possui contas de usuários com mudanças frequentes de pessoal? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

46. Existe processo formal que bloqueia todos os acessos no dia do desligamento, com confirmação documentada?

Evidência esperada: Checklists de desligamento; logs de bloqueio; relatórios de conciliação · Indicador sugerido: N° de contas ativas sem vínculo; tempo médio entre desligamento e bloqueio; % de bloqueios no prazo

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

47. Os gestores revisam formalmente, ao menos semestralmente, os acessos de suas equipes aos sistemas?

Evidência esperada: Atas e relatórios de recertificação; matriz perfil x função; registros de revogação · Indicador sugerido: % de sistemas críticos com revisão no prazo; n° de acessos revogados por campanha; % de usuários com perfil múltiplo

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

48. O uso de contas genéricas (compartilhadas por várias pessoas, como admin, suporte ou plantão) é restrito aos casos inevitáveis, e cada uma tem justificativa formal, um responsável pela senha e um registro de quem a usou e quando?

Orientação: conta genérica é a que não identifica uma pessoa. O registro de uso pode ser uma escala de plantão, um livro de uso ou um cofre de senhas com retirada registrada. Não ter nenhuma conta genérica também conta como prática adotada, desde que seja regra definida e verificada. · Evidência esperada: Inventário de contas; termos de custódia; registros de rotação de senha; escalas · Indicador sugerido: N° de contas genéricas ativas; % com custódia formal; n° de sistemas sem suporte a conta nominal

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 10. Desenvolvimento

Pergunta de triagem: O órgão desenvolve, mantém ou implanta sistemas e novas versões? ☐ Sim ☐ Não
Se "não", passe para a próxima seção.

49. Existem requisitos de segurança definidos, revisão de código e testes de segurança antes da entrada em produção?

Evidência esperada: Padrão documentado; relatórios de teste; registros de revisão de código; termos de aceite com requisitos de segurança · Indicador sugerido: N° de falhas críticas por aplicação; % de sistemas com teste de segurança antes da produção; tempo médio de correção

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

50. Os ambientes são separados, com credenciais distintas e processo formal de promoção de versões?

Evidência esperada: Topologia dos ambientes; registros de promoção de versão; matriz de acessos · Indicador sugerido: N° de alterações aplicadas diretamente em produção; % de sistemas com ambientes segregados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

51. Os dados usados em teste são anonimizados ou mascarados? Há registro e autorização das cópias de produção?

Evidência esperada: Procedimento de mascaramento; autorizações de cópia; registros de expurgo · Indicador sugerido: N° de bases de teste com dados reais; % de ambientes com mascaramento; n° de cópias não autorizadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

52. Os sistemas registram acessos, consultas e alterações, com data, usuário, origem e retenção definida em local protegido?

Evidência esperada: Configuração de log; amostras de trilha; política de retenção; registros de revisão · Indicador sugerido: % de sistemas críticos com trilha completa; dias de retenção; n° de interrupções de coleta

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

53. Existe homologação com aceite formal do gestor de negócio e plano de reversão antes de cada publicação?

Evidência esperada: Roteiros e resultados de homologação; termos de aceite; registros de publicação e de reversão · Indicador sugerido: Taxa de reversão; n° de incidentes nas 48h após publicação; % de publicações com aceite formal

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

54. Os projetos possuem patrocinador, escopo formal, cronograma, riscos mapeados e acompanhamento periódico?

Evidência esperada: Termos de abertura; cronogramas; atas de acompanhamento; registros de riscos · Indicador sugerido: % de projetos no prazo; desvio médio de prazo e custo; n° de projetos sem patrocinador

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

55. Os requisitos foram levantados com as áreas, validados formalmente e incluem aspectos legais, de segurança e de privacidade?

Evidência esperada: Documento de requisitos validado; atas de homologação; matriz de rastreabilidade · Indicador sugerido: % de requisitos validados formalmente; nº de mudanças de requisito após o desenvolvimento; adesão pós-implantação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

56. Existe plano de gestão da mudança, com capacitação, comunicação e acompanhamento de uso após a implantação?

Evidência esperada: Plano de adoção; registros de capacitação; indicadores de uso · Indicador sugerido: % de uso efetivo; nº de processos paralelos identificados; satisfação dos usuários

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 11. Integrações

Pergunta de triagem: O órgão usa integrações, APIs (interfaces que permitem a um sistema trocar dados com outro), automações ou troca sistemas e fornecedores? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

57. Existe inventário de contas de serviço com dono, escopo mínimo e rotina de rotação de credenciais?

Evidência esperada: Inventário de contas de serviço; registros de rotação; documentação de escopo · Indicador sugerido: Nº de contas de serviço sem dono; idade média das credenciais; % com privilégio administrativo

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

58. Existe verificação automatizada de segredos nos repositórios e uso de cofre para credenciais de aplicação?

Evidência esperada: Configuração da verificação automatizada; registros de rotação; política de repositórios · Indicador sugerido: Nº de segredos detectados; tempo médio de rotação após detecção; % de repositórios com verificação ativa

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

59. Para cada sistema, existe uma lista das bibliotecas e componentes de terceiros que ele usa (SBOM), e essa lista é verificada periodicamente contra vulnerabilidades conhecidas?

Orientação: todo sistema é montado com peças prontas de terceiros (bibliotecas, frameworks, pacotes de código aberto). Quando uma delas tem falha publicada, como aconteceu com o Log4j em 2021, é preciso saber quais sistemas a usam. A verificação costuma ser feita por ferramentas de análise de dependências, como Dependabot ou OWASP Dependency-Check. Vale também para sistemas de fornecedores: a lista e a verificação podem ser exigidas em contrato. · Evidência esperada: SBOM por sistema; relatórios de análise de composição; registros de atualização · Indicador sugerido: N° de dependências vulneráveis críticas; idade média das dependências; % de sistemas com SBOM

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

60. As APIs (interfaces que permitem a um sistema trocar dados com outro) exigem autenticação, aplicam autorização por registro, limitam volume e retornam apenas os campos necessários?

Evidência esperada: Documentação das APIs; configuração do gateway; registros de consumo; relatórios de teste · Indicador sugerido: Volume por consumidor x baseline; n° de APIs sem gateway; n° de falhas de autorização detectadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

61. A migração possui plano documentado, testes com validação por amostragem, critérios de aceite e plano de reversão?

Evidência esperada: Plano de migração; relatórios de validação; termo de aceite; cópia íntegra da base de origem · Indicador sugerido: % de divergência entre origem e destino; n° de registros rejeitados; n° de correções pós-migração

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

62. Existe fonte autoritativa definida por tipo de dado, com monitoramento das integrações e rotina de reconciliação?

Evidência esperada: Mapa de integrações; definição de fontes autoritativas; relatórios de reconciliação · Indicador sugerido: N° de divergências detectadas; % de mensagens com erro; atraso médio de sincronização

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

63. As automações em produção são versionadas, revisadas, monitoradas e possuem limites de segurança?

Evidência esperada: Repositório de scripts; registros de revisão; logs de execução; inventário de jobs · Indicador sugerido: N° de automações sem dono; n° de execuções com erro; volume médio afetado por execução

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

64. Existe plano de transição contratual com repasse documentado, revogação de acessos e período de sobreposição?

Evidência esperada: Plano de transição; termos de repasse; registros de revogação de acessos · Indicador sugerido: N° de acessos residuais identificados; n° de incidentes no período de transição; % de entregáveis de transição cumpridos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 12. Dados e serviços

Pergunta de triagem: O órgão oferece serviços digitais ou trata dados pessoais, sigilosos ou públicos? ☐ Sim
☐ Não

Se "não", passe para a próxima seção.

65. Existe norma de classificação da informação aplicada aos documentos, bases e sistemas?

Evidência esperada: Norma; matriz de classificação; ativos rotulados; registros de treinamento · Indicador sugerido: % de bases críticas classificadas; n° de achados de dados sensíveis em repositórios abertos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

66. O nível de autenticação exigido é proporcional ao risco do serviço, com fatores que não sejam dados públicos?

Evidência esperada: Matriz de nível de garantia por serviço; configuração de autenticação; registros de fraude tratada · Indicador sugerido: N° de contestações de acesso indevido; % de serviços sensíveis com MFA (autenticação em mais de um fator, como senha e código no celular); tempo de resposta a suspeita de fraude

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

67. Os serviços digitais foram avaliados quanto à acessibilidade e testados com usuários reais?

Evidência esperada: Relatórios de avaliação de acessibilidade; testes com usuários; requisitos contratuais · Indicador sugerido: N° de barreiras críticas de acessibilidade; taxa de conclusão dos serviços digitais; n° de reclamações

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

68. O tráfego usa TLS (criptografia da conexão, o cadeado do navegador) atualizado e os dados sensíveis em repouso, backups e dispositivos móveis estão criptografados?

Evidência esperada: Configuração TLS; inventário de certificados; evidência de criptografia de disco e de backup; política de chaves · Indicador sugerido: % de serviços com TLS adequado; % de notebooks com disco criptografado; certificados próximos do vencimento

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

69. Existem controles para detectar e limitar a extração de grandes volumes de dados e o uso de canais não autorizados?

Evidência esperada: Políticas e bloqueios implantados; relatórios de monitoramento; plano de resposta a incidentes · Indicador sugerido: N° de alertas de exportação em massa; n° de incidentes confirmados; tempo de detecção

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

70. Existe tabela de temporalidade aplicada aos sistemas e backups, com rotina de eliminação registrada?

Evidência esperada: Tabela de temporalidade; rotinas de expurgo; termos de eliminação · Indicador sugerido: Volume de dados fora do prazo de retenção; % de sistemas com regra de retenção aplicada

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

71. As bases publicadas passaram por avaliação de risco de reidentificação com técnicas adequadas de anonimização?

Evidência esperada: Metodologia; pareceres; registros de avaliação de risco; versões publicadas · Indicador sugerido: N° de bases publicadas com avaliação formal; n° de achados de reidentificação; tempo de resposta a alerta

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

72. Existe plano de comunicação de crise com porta-voz definido, mensagens padrão e canais alternativos?

Evidência esperada: Plano de comunicação; registros de comunicados; página de status · Indicador sugerido: Tempo até a primeira comunicação oficial; volume de reclamações; alcance dos comunicados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 13. Fornecedores

Pergunta de triagem: O órgão contrata fornecedores para bens, sistemas ou serviços de TI? (inclui contratos de nuvem e SaaS (sistema usado pela internet e contratado como serviço)) ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

73. A contratação possui estudo técnico preliminar, requisitos objetivos, análise de riscos e critérios de aceite?

Evidência esperada: ETP (estudo técnico preliminar); termo de referência; análise de riscos; pareceres; relatórios de execução · Indicador sugerido: % de contratações com ETP; nº de aditivos por contrato; nº de impugnações

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

74. Existe avaliação de segurança e privacidade dos fornecedores antes da contratação e durante a execução?

Evidência esperada: Questionários preenchidos; cláusulas contratuais; certificações; relatórios de avaliação · Indicador sugerido: % de fornecedores críticos avaliados; nº de cláusulas de segurança ausentes; nº de incidentes originados em terceiros

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

75. O acesso de fornecedores é nominal, temporário, com escopo mínimo, supervisionado e registrado?

Evidência esperada: Cadastro de contas de fornecedores; termos assinados; registros de sessão; chamados vinculados · Indicador sugerido: Nº de contas de fornecedor ativas sem demanda; % de acessos vinculados a chamado; nº de acessos fora do horário

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

76. Se o fornecedor de um sistema crítico falir, abandonar o contrato ou descontinuar o produto de forma inesperada, existe plano para continuar operando, com acesso garantido aos dados e à documentação?

Evidência esperada: Contrato de custódia; cópias de dados e documentação; plano de substituição · Indicador sugerido: Nº de sistemas críticos com fornecedor único; % com dados exportáveis; existência de custódia

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

77. O contrato exige autorização prévia para subcontratação e a lista de subcontratados é conhecida e atualizada?

Evidência esperada: Cláusulas contratuais; lista de subcontratados; autorizações formais · Indicador sugerido: % de contratos com cláusula de subcontratação; nº de subcontratados não declarados identificados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

78. Os contratos possuem instrumentos de medição objetivos, com relatórios verificados antes do pagamento?

Evidência esperada: Relatórios de medição; termos de recebimento; registros de glosa e sanções · Indicador sugerido: % de contratos com medição objetiva; nº de glosas aplicadas; nº de contratos por fiscal

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 14. Nuvem

Pergunta de triagem: O órgão utiliza nuvem pública, privada, SaaS (sistema usado pela internet e contratado como serviço) ou serviços hospedados externamente? (aqui entram só os riscos próprios da nuvem; o contrato em si é tratado em Fornecedores) ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

79. Está documentado, para cada serviço de nuvem, o que é responsabilidade do provedor e o que é do órgão, por exemplo quem aplica atualizações, configura acessos e faz backup?

Evidência esperada: Contrato com requisitos; matriz de responsabilidades; certificações do provedor; relatórios de conformidade · Indicador sugerido: % de contratos de nuvem com matriz definida; nº de requisitos não atendidos; nº de serviços sem backup contratado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

80. Existe verificação contínua de configuração da nuvem, com bloqueio de exposição pública e revisão de permissões?

Evidência esperada: Relatórios de postura; políticas aplicadas na conta; registros de correção · Indicador sugerido: Nº de recursos expostos publicamente; nº de identidades com privilégio amplo; tempo de correção de achados críticos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

81. Se o órgão decidir trocar de provedor de nuvem, o contrato garante a exportação dos dados em formato aberto, um prazo de transição e apoio do provedor na migração?

Evidência esperada: Cláusulas contratuais; registros de exportação e teste; plano de saída documentado · Indicador sugerido: % de contratos com cláusula de reversibilidade; data do último teste de exportação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

82. Se o serviço de nuvem ficar fora do ar por horas ou dias, existe plano de contingência, com cópia dos dados fora do provedor e uma forma alternativa de operar?

Evidência esperada: Arquitetura de resiliência; plano de contingência; registros de indisponibilidade e de acionamento do SLA (nível de serviço contratado: prazos e disponibilidade garantidos) · Indicador sugerido: Disponibilidade contratada x realizada; n° de horas de indisponibilidade por trimestre; data do último teste de contingência

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

83. Existem alertas de custo, marcação por projeto e revisão periódica de recursos ociosos?

Evidência esperada: Painéis de custo; política de marcação; relatórios de otimização · Indicador sugerido: Desvio entre custo previsto e realizado; % de recursos sem marcação; custo de recursos ociosos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

84. Sabe-se em quais países os dados são armazenados e processados, incluindo backups, logs e subprocessadores?

Evidência esperada: Configuração de região; contrato com cláusula de localização; lista de subprocessadores; parecer jurídico · Indicador sugerido: % de serviços com localização de dados definida; n° de subprocessadores não mapeados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 15. Rotinas críticas

Pergunta de triagem: O órgão executa rotinas críticas de TI com equipe própria ou reduzida? ☐ Sim ☐ Não
Se "não", passe para a próxima seção.

85. Existe pelo menos um substituto capacitado e documentação suficiente para operar cada serviço crítico?

Evidência esperada: Mapa de conhecimento; registros de capacitação; procedimentos documentados; cofre de credenciais · Indicador sugerido: N° de serviços críticos com um único responsável; % de procedimentos documentados; n° de substitutos treinados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

86. Todas as demandas de TI são registradas em ferramenta, com categorização, prioridade e prazo acordado?

Evidência esperada: Ferramenta em uso; catálogo com SLA (nível de serviço contratado: prazos e disponibilidade garantidos); relatórios gerenciais · Indicador sugerido: % de demandas registradas; % de atendimentos dentro do prazo; taxa de reincidência

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

87. As rotinas críticas possuem procedimento operacional documentado, atualizado e com registro de execução?

Evidência esperada: POP (procedimento operacional padrão) publicados; checklists preenchidos; registros de execução automatizada · Indicador sugerido: % de rotinas críticas com POP; nº de falhas por não execução; idade média dos procedimentos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

88. Operações críticas exigem dupla conferência, confirmação explícita e possuem plano de reversão?

Evidência esperada: Registros de dupla conferência; scripts revisados; logs de operação · Indicador sugerido: Nº de incidentes por erro operacional; % de operações críticas com dupla conferência

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

89. Existe processo de gestão de problemas com análise de causa raiz para incidentes recorrentes e de alto impacto?

Evidência esperada: Registros de problemas; relatórios de causa raiz; plano de ação com prazos · Indicador sugerido: Taxa de reincidência; nº de problemas abertos sem solução definitiva; tempo médio de resolução

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 16. Mobilidade e e-mail

Pergunta de triagem: O órgão usa e-mail institucional, teletrabalho, dispositivos pessoais ou atendimento externo? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

90. Existem filtros de e-mail, MFA (autenticação em mais de um fator, como senha e código no celular), simulações de phishing e procedimento de verificação para solicitações sensíveis?

Evidência esperada: Configuração dos filtros; relatórios de simulação; registros de reportes e tratativas · Indicador sugerido: Taxa de clique e de reporte em simulações; nº de mensagens maliciosas bloqueadas; nº de fraudes tentadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

91. Existe política de trabalho remoto e BYOD (uso de dispositivos pessoais no trabalho), com requisitos mínimos de segurança verificáveis nos dispositivos?

Evidência esperada: Política publicada; termos de uso de equipamento; relatórios de conformidade dos dispositivos · Indicador sugerido: % de dispositivos remotos gerenciados; nº de acessos de dispositivos não conformes; nº de perdas relatadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 17. Inteligência artificial

Pergunta de triagem: O órgão utiliza ferramentas de inteligência artificial em trabalho ou atendimento? ☐

Sim ☐ Não

Se "não", passe para a próxima seção.

92. Existe política de uso de IA, inventário das aplicações em uso e definição de supervisão humana e responsabilidades?

Evidência esperada: Política; inventário de casos de uso; avaliações de risco; registros de supervisão · Indicador sugerido: Nº de usos de IA inventariados x identificados; % com avaliação de risco; nº de contestações

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

93. Existe orientação formal sobre o que pode ser inserido em ferramentas de IA e alternativa corporativa disponível?

Evidência esperada: Norma publicada; termos de ciência; registros de homologação de ferramentas · Indicador sugerido: Nº de ferramentas de IA homologadas; acessos a plataformas não homologadas; nº de incidentes reportados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

94. As decisões automatizadas são documentadas, explicáveis, registradas e passíveis de revisão humana mediante solicitação?

Evidência esperada: Documentação do modelo; registros de decisão; relatórios de auditoria de viés; canal de revisão em operação · Indicador sugerido: Taxa de reversão em revisões; disparidade de resultados entre grupos; nº de contestações

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 18. Cidade conectada

Pergunta de triagem: O município possui alguma iniciativa urbana conectada ou tecnologia em espaço público?

- ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

95. Existe plano municipal de cidade inteligente com arquitetura de referência, governança intersetorial e prioridades definidas?

Evidência esperada: Plano municipal; atas do comitê; arquitetura de referência; portfólio de projetos urbanos · Indicador sugerido: Nº de plataformas urbanas sobrepostas; % de projetos aderentes à arquitetura; nº de soluções sem uso efetivo

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

96. O projeto prevê custo total de propriedade, contrato de manutenção, conectividade e renovação do parque?

Evidência esperada: Estudo de custo total de propriedade; contratos de manutenção; inventário com status · Indicador sugerido: % de equipamentos urbanos operantes; idade média do parque; custo anual de sustentação previsto x executado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

97. O contrato define a propriedade dos dados, o acesso do município em tempo real e as condições de reversão da infraestrutura digital?

Evidência esperada: Cláusulas contratuais; acessos concedidos ao município; registros de fiscalização · Indicador sugerido: % de contratos de concessão com cláusula de dados; nº de bases não acessíveis ao município

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

98. A população é informada sobre a existência, a finalidade e o responsável pelo monitoramento urbano?

Evidência esperada: Registros fotográficos da sinalização; publicações oficiais; atas de consulta pública · Indicador sugerido: % de pontos de coleta sinalizados; nº de pedidos de informação sobre monitoramento; nº de manifestações contrárias

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

99. Os editais exigem padrões abertos, APIs (interfaces que permitem a um sistema trocar dados com outro) documentadas e propriedade dos dados pelo município?

Evidência esperada: Requisitos nos editais; documentação de APIs; catálogo de dados urbanos · Indicador sugerido: % de soluções com API documentada; nº de integrações contratadas separadamente

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 19. Campo e conectividade

Pergunta de triagem: O município opera dispositivos conectados, rede urbana, Wi-Fi público ou conectividade móvel? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

100. Existe procedimento de hardening na instalação, com troca de credenciais, atualização de firmware e inventário dos dispositivos?

Evidência esperada: Checklist de instalação; inventário com firmware; relatórios de varredura; requisitos contratuais · Indicador sugerido: % de dispositivos com credencial padrão; % com firmware atualizado; nº de dispositivos comprometidos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

101. Os equipamentos em campo possuem proteção física, sensor de violação e monitoramento de integridade?

Evidência esperada: Especificação dos gabinetes; registros de alertas de violação; relatórios de inspeção · Indicador sugerido: Nº de equipamentos danificados ou furtados por período; tempo médio de reposição; nº de alertas de violação

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

102. Existe plataforma única de gestão de dispositivos com inventário, status, versão de firmware e responsável?

Evidência esperada: Inventário georreferenciado; relatórios de status; registros de baixa · Indicador sugerido: % de dispositivos inventariados; nº de dispositivos sem comunicação há mais de 30 dias; nº de SIM cards (chips de celular) ativos sem dispositivo

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

103. A comunicação dos dispositivos usa criptografia e autenticação mútua, com chaves individuais por equipamento?

Evidência esperada: Especificação técnica; configuração de certificados; relatórios de análise de tráfego · Indicador sugerido: % de dispositivos com comunicação criptografada; nº de leituras anômalas detectadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

104. Existe capacidade de atualização remota segura, com implantação gradual e grupo piloto antes da atualização geral?

Evidência esperada: Procedimento de atualização; registros de implantação por grupo; contratos com suporte de firmware · Indicador sugerido: % do parque atualizável remotamente; tempo para atualizar todo o parque; nº de falhas após atualização

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

105. Existe monitoramento de energia e autonomia dos dispositivos, com alerta e manutenção preventiva programada?

Evidência esperada: Relatórios de disponibilidade; plano de manutenção; registros de substituição · Indicador sugerido: % de dispositivos com energia monitorada; nº de pontos inoperantes; tempo médio de reposição

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

106. A rede de dispositivos de campo é segregada da rede administrativa, com filtragem e negação por padrão entre elas?

Evidência esperada: Diagrama de segmentação; matriz de comunicação; testes de isolamento · Indicador sugerido: Nº de fluxos permitidos entre campo e administrativo; resultado dos testes de isolamento

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

107. A topologia da rede possui rotas redundantes para as unidades e pontos críticos, com failover testado?

Evidência esperada: Topologia documentada; registros de teste de failover; relatórios de disponibilidade · Indicador sugerido: % de pontos críticos com rota redundante; tempo médio de reparo; nº de rompimentos por período

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

108. A rede pública isola os usuários entre si, protege os dados de cadastro e mantém registros conforme a legislação?

Evidência esperada: Configuração dos controladores; aviso de privacidade publicado; política de retenção dos registros · Indicador sugerido: Nº de dados coletados no cadastro; resultado dos testes de isolamento; nº de incidentes reportados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

109. Existe alternativa de conectividade para os pontos críticos e verificação da tecnologia suportada pelos dispositivos?

Evidência esperada: Mapa de cobertura; contratos de conectividade; inventário com tecnologia suportada · Indicador sugerido: % de pontos críticos com conectividade redundante; nº de dispositivos em tecnologia descontinuada

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

110. Existe mapeamento das áreas com menor acesso digital e garantia de canal alternativo para todos os serviços?

Evidência esperada: Mapeamento territorial; registros dos pontos de acesso; indicadores de uso por região · Indicador sugerido: Cobertura de acesso por região; % de serviços com canal alternativo; demanda presencial por serviço digital

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 20. Mobilidade e serviços

Pergunta de triagem: O município opera mobilidade inteligente, automação urbana ou telegestão de serviços essenciais? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

111. Os controladores possuem autenticação, rede segregada, modo seguro de falha e procedimento manual de contingência?

Evidência esperada: Arquitetura de rede segregada; configuração dos controladores; plano de contingência de trânsito · Indicador sugerido: % de controladores em rede segregada; nº de falhas por período; tempo de resposta em contingência

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

112. A tecnologia de bilhetagem é resistente a clonagem, e os dados de viagem são minimizados e protegidos?

Evidência esperada: Especificação tecnológica; relatórios de conciliação; avaliação de segurança do sistema · Indicador sugerido: Perda estimada por fraude; nº de cartões bloqueados; volume de dados de viagem retido

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

113. Os dados de localização são minimizados, com prazo de retenção definido e acesso restrito e auditado?

Evidência esperada: Política de retenção; registros de acesso; documentação das APIs (interfaces que permitem a um sistema trocar dados com outro); aviso de privacidade · Indicador sugerido: Prazo de retenção de dados individualizados; nº de consultas a trajetos específicos; nº de APIs expostas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

114. Os equipamentos possuem aferição válida, sincronismo de horário verificado e integridade comprovável dos registros?

Evidência esperada: Certificados de aferição; registros de sincronismo; evidências de integridade das imagens · Indicador sugerido: % de equipamentos com aferição vigente; índice de recursos deferidos; desvio de horário verificado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

115. As permissões e as coletas do aplicativo são mínimas, documentadas e informadas no aviso de privacidade?

Evidência esperada: Análise de privacidade do aplicativo; lista de permissões justificadas; aviso de privacidade publicado · Indicador sugerido: Nº de permissões solicitadas x justificadas; nº de SDKs (componentes de terceiros embutidos no aplicativo, como os de anúncio ou estatística) de terceiros; nº de reclamações de usuários

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

116. O ambiente OT (tecnologia operacional: equipamentos que controlam processos físicos, como semáforos, bombas e iluminação) é segmentado da rede corporativa, com acesso remoto controlado, inventário e monitoramento específicos?

Evidência esperada: Arquitetura de zonas e condutos; inventário OT; registros de acesso remoto; plano de resposta específico ·

Indicador sugerido: N° de conexões diretas entre TI e OT; % de ativos OT inventariados; tempo de detecção em exercícios

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

117. O acesso à plataforma de telegestão exige MFA (autenticação em mais de um fator, como senha e código no celular), os comandos em massa requerem dupla confirmação e existe modo local de operação?

Evidência esperada: Configuração da plataforma; registros de comandos; cláusulas contratuais de segurança · Indicador sugerido:

N° de comandos em massa executados; % de pontos com modo local; n° de acessos administrativos

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

118. A granularidade da coleta é a mínima necessária, com agregação, prazo de retenção definido e acesso restrito?

Evidência esperada: Especificação da coleta; política de retenção; registros de acesso; contratos com a concessionária · Indicador

sugerido: Intervalo de coleta praticado; prazo de retenção de dados granulares; n° de acessos à base

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

119. Existe mapa de interdependências entre os serviços urbanos digitalizados e plano integrado de continuidade?

Evidência esperada: Mapa de interdependências; plano integrado; registros de exercícios conjuntos · Indicador sugerido: N° de serviços dependentes de um mesmo componente; data do último exercício conjunto

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 21. Plataforma e monitoramento

Pergunta de triagem: O município possui plataforma urbana, centro de operações ou videomonitoramento público? ☐ Sim ☐ Não

Se "não", passe para a próxima seção.

120. Existe segregação de acesso por domínio na plataforma, com perfis mínimos e trilha de auditoria por consulta?

Evidência esperada: Matriz de perfis por domínio; trilhas de auditoria; arquitetura de redundância · Indicador sugerido: N° de usuários com acesso a múltiplos domínios; n° de consultas atípicas; disponibilidade da plataforma

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

121. Existem protocolos formais por tipo de ocorrência, escala definida, sala alternativa e exercícios periódicos?

Evidência esperada: Protocolos publicados; registros de exercícios; escalas; relatórios pós-evento · Indicador sugerido: Tempo médio de resposta por tipo de ocorrência; n° de exercícios realizados; disponibilidade da sala

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

122. Existem calibração periódica dos sensores, indicadores de qualidade dos dados e sinalização de lacunas nos painéis?

Evidência esperada: Plano de calibração; relatórios de qualidade; documentação de metadados · Indicador sugerido: % de sensores calibrados no prazo; completude das séries; n° de correções em painéis publicados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

123. Existe procedimento de avaliação de sensibilidade e de risco de reidentificação antes da publicação de dados urbanos?

Evidência esperada: Metodologia; pareceres; registros de avaliação por base publicada · Indicador sugerido: % de bases publicadas com avaliação prévia; n° de bases retiradas após revisão

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

124. Todo compartilhamento de dados entre órgãos possui instrumento formal com finalidade, escopo e prazo definidos?

Evidência esperada: Convênios e acordos; pareceres; inventário de compartilhamentos; registros de acesso · Indicador sugerido: % de compartilhamentos formalizados; n° de acessos concedidos sem instrumento; n° de revisões realizadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

125. Existe política de acesso a imagens, com perfis nominais, registro de cada visualização e exportação e auditoria periódica?

Evidência esperada: Política; trilhas de acesso; autorizações de exportação; relatórios de auditoria · Indicador sugerido: N° de exportações sem autorização; n° de consultas atípicas; % de operadores com termo assinado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

126. Existe base legal específica, relatório de impacto à proteção de dados, supervisão humana e avaliação de viés antes do uso?

Evidência esperada: RIPD (relatório de impacto à proteção de dados pessoais); norma que autoriza o uso; registros de supervisão humana; relatórios de acurácia e viés · Indicador sugerido: Taxa de falsos positivos por grupo demográfico; n° de abordagens revertidas; existência e data do RIPD

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

127. Existe prazo de retenção definido e aplicado automaticamente, com controle das cópias exportadas?

Evidência esperada: Política de retenção; configuração dos gravadores; registro de exportações e eliminações · Indicador sugerido: Prazo médio de retenção praticado; n° de cópias exportadas sem prazo de eliminação; volume armazenado

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

128. Existem testes periódicos de ponta a ponta dos sistemas de alerta, com redundância de canais e monitoramento de disponibilidade?

Evidência esperada: Registros de teste; relatórios de disponibilidade; plano de contingência de alerta · Indicador sugerido: % de sensores críticos operantes; data do último teste completo; tempo de propagação do alerta em teste

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

129. A finalidade de cada sistema urbano está documentada, e há controle formal sobre pedidos de uso para outros fins?

Evidência esperada: Registro de finalidades; procedimento de atendimento a pedidos; pareceres; relatórios de auditoria · Indicador sugerido: N° de pedidos de acesso por finalidade diversa; % atendidos com formalização; n° de acessos informais identificados

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

Seção 22. Serviços ao cidadão

Pergunta de triagem: O município oferece portal, aplicativo ou serviços digitais urbanos ao cidadão? ☐ Sim
☐ Não

Se "não", passe para a próxima seção.

130. Existe cadastro único ou integração com identidade digital oficial, com nível de autenticação proporcional ao risco do serviço?

Evidência esperada: Arquitetura de identidade; matriz de níveis por serviço; relatórios de deduplicação · Indicador sugerido: % de duplicidade nos cadastros; % de serviços integrados à identidade digital; nº de fraudes identificadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

131. O portal possui WAF (firewall de aplicação web, que filtra ataques ao site), proteção contra negação de serviço, CMS (sistema de gerenciamento do conteúdo do portal, como WordPress ou Joomla) atualizado e monitoramento de domínios semelhantes?

Evidência esperada: Configuração de WAF; registros de atualização; relatórios de monitoramento de marca · Indicador sugerido: Disponibilidade do portal; nº de domínios falsos identificados; nº de vulnerabilidades críticas abertas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

132. A plataforma verifica a identidade de forma proporcional, limita participações e permite auditoria dos resultados?

Evidência esperada: Regras publicadas; registros auditáveis; relatórios de análise de integridade · Indicador sugerido: % de participações suspeitas; nº de contestações; taxa de participações por identidade

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

133. Cada integração analítica possui finalidade definida, avaliação de impacto e uso preferencial de dados agregados ou anonimizados?

Evidência esperada: RIPD (relatório de impacto à proteção de dados pessoais); atas de aprovação; documentação das integrações; relatórios de auditoria · Indicador sugerido: Nº de integrações com RIPD; % de análises com dados agregados; nº de achados de viés

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota

134. As camadas do modelo são classificadas por sensibilidade, com acesso segregado e avaliação de risco antes de qualquer publicação?

Evidência esperada: Matriz de classificação das camadas; registros de acesso; avaliações de risco; acordos com parceiros

Indicador sugerido: N° de camadas sensíveis com acesso amplo; n° de acessos externos; % de camadas classificadas

- ☐ Adota integralmente, com monitoramento e maturidade definida
- ☐ Adota integralmente
- ☐ Adota parcialmente
- ☐ Adota informalmente
- ☐ Não adota